

RELAZIONE DI ANALISI MALWARE

Lana Mazibrada → Esercizio 5 – ANY.RUN | Analisi del primo link

Campione analizzato: 66bdfcb52736_vidar.exe

Data osservata nell'ambiente di analisi: 25 agosto 2024

Piattaforma: ANY.RUN – Windows 10 64 bit

Obiettivo dell'analisi: descrivere in modo comprensibile ma tecnicamente fondato il comportamento del campione, valutare se la rilevazione sia attendibile e indicare le azioni di risposta più appropriate.

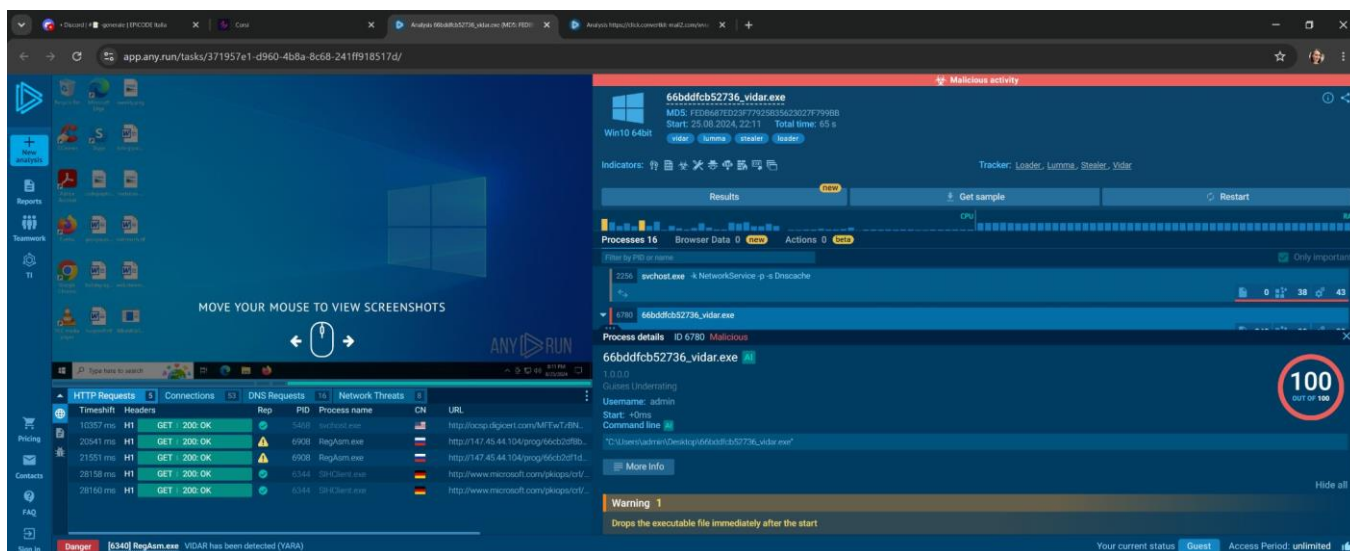


Figura 1 – Panoramica iniziale del task ANY.RUN e classificazione generale del campione.

1. Sintesi dell'analisi

Dall'analisi del primo task ANY.RUN emerge un quadro di compromissione **ad alta confidenza**. Il campione viene classificato dalla piattaforma come **Malicious**, con **punteggio 100/100**, e il tracker del task riporta riferimenti alle categorie *Loader*, *Lumma*, *Stealer* e *Vidar*. L'elemento più significativo, tuttavia, è la presenza di una rilevazione esplicita **“VIDAR has been detected (YARA)”** all'interno della catena di esecuzione.

Non considero questa sola etichetta sufficiente per ricostruire con certezza tutta la famiglia o ogni stadio della catena, ma, insieme al comportamento osservato, costituisce una forte evidenza che il campione sia malevolo e che presenti caratteristiche compatibili con malware di tipo information stealer/loader.

Valutazione finale: ritengo che il rilevamento sia un vero positivo. Non emergono elementi sufficienti per trattarlo come falso positivo o per consentirne l'esecuzione.

2. Dati principali rilevati

Elemento	Osservazione
Sistema sandbox	Windows 10 64 bit
Durata osservata	Circa 65 secondi
Verdetto generale	Malicious – 100/100
Tracker ANY.RUN	Loader, Lumma, Stealer, Vidar
Processo particolarmente rilevante	eRegAsm.exe, utility Microsoft .NET
Rilevazione più forte	VIDAR has been detected (YARA)
Comportamento aggiuntivo	Creazione immediata di un file temporaneo e attività di discovery

3. Analisi del processo RegAsm.exe

Uno dei punti più importanti dell'analisi riguarda **RegAsm.exe**. ANY.RUN mostra il processo come proveniente dal percorso `C:\Windows\Microsoft.NET\Framework\v4.0.30319\RegAsm.exe` e lo identifica come componente Microsoft (Microsoft .NET Assembly Registration Utility). Questo dettaglio è fondamentale: **RegAsm.exe è un programma legittimo e non deve essere considerato malware solo per il suo nome.**

Nel contesto osservato, però, il processo è coinvolto in una catena anomala e viene classificato con **Threat Verdict: Malicious 100/100**. La schermata mostra inoltre più istanze di RegAsm.exe e processi di supporto come cmd.exe, conhost.exe e Timeout.exe. Questo è coerente con un possibile abuso di un binario legittimo all'interno della catena di esecuzione. La conclusione corretta, quindi, non è che RegAsm.exe sia intrinsecamente malevolo, ma che **in questo caso venga utilizzato in un contesto malevolo.**

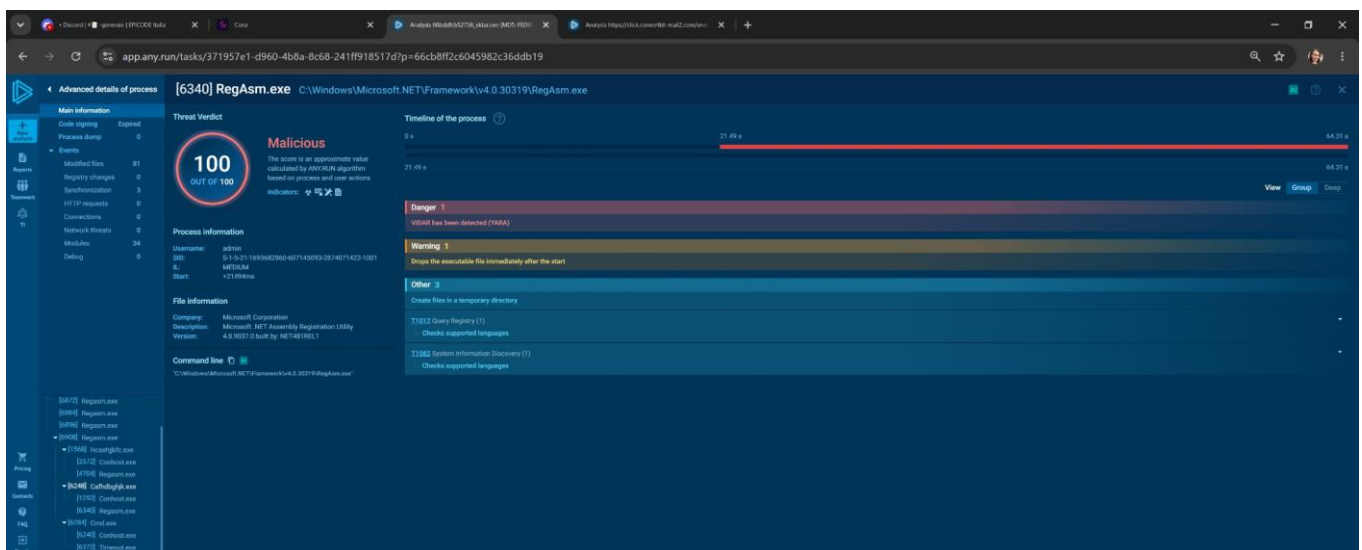


Figura 2 – Dettaglio del processo RegAsm.exe, classificato 100/100 come malevolo nel contesto della catena osservata.

4. Evidenze tecniche più rilevanti

4.1 Rilevazione YARA: VIDAR

Nella vista dettagliata del processo compare l'evento “**VIDAR has been detected (YARA)**”, ripetuto più volte nella timeline. Una regola YARA identifica caratteristiche del contenuto o del comportamento riconducibili a una determinata famiglia o a un insieme di indicatori. Nel report considero questa una delle prove più forti dell'analisi, perché non si tratta soltanto di un generico punteggio euristico.

La presenza contemporanea dei riferimenti a Vidar e, nella panoramica di rete, a Lumma Stealer suggerisce che la piattaforma abbia individuato indicatori appartenenti a più componenti o firme di malware stealer/loader. Per correttezza tecnica, dagli screenshot non posso stabilire con assoluta certezza quale componente rappresenti lo stadio finale della catena; posso però affermare che l'insieme delle evidenze indica chiaramente un comportamento malevolo.

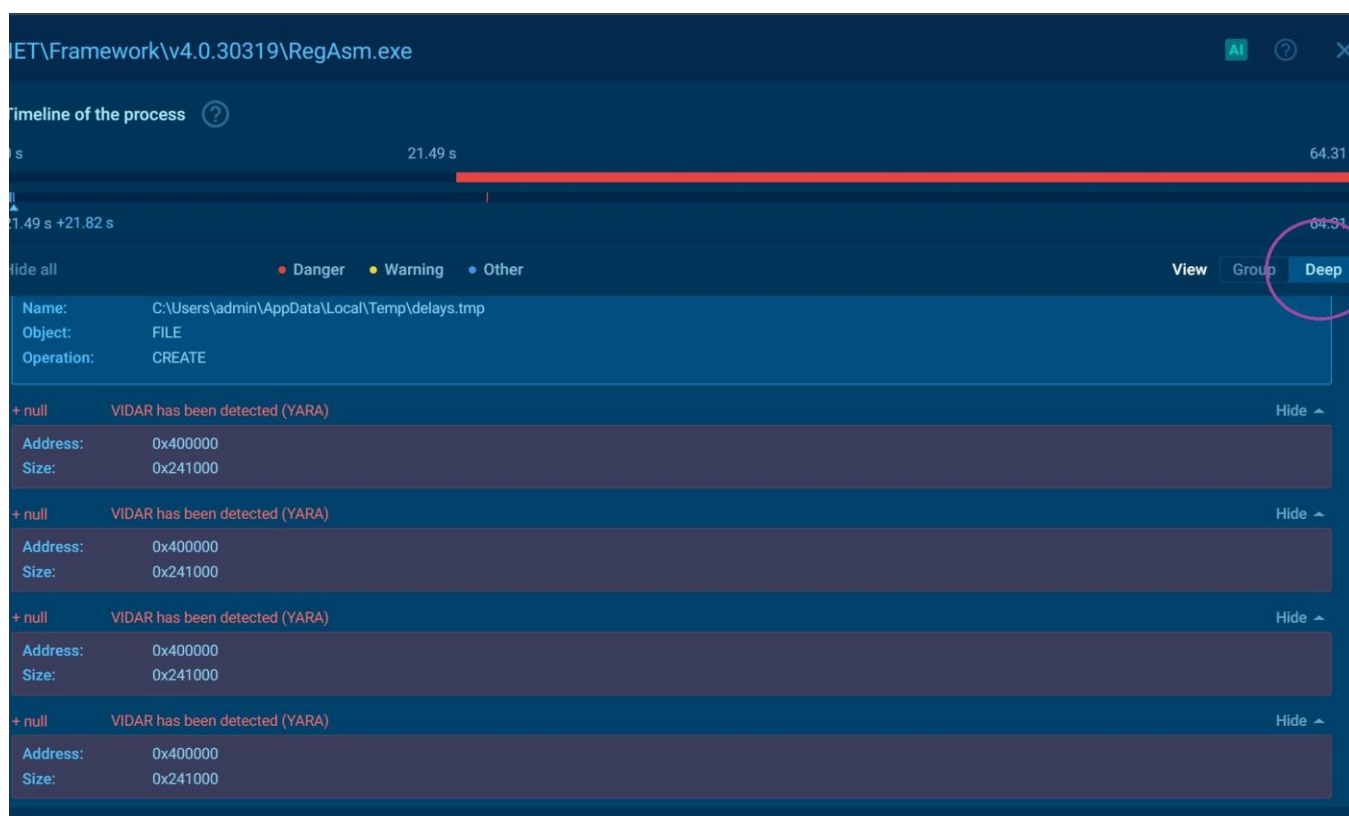


Figura 3 – Vista Deep della timeline: detection YARA di VIDAR, creazione di file temporanei e attività di discovery.

4.2 File temporaneo creato subito dopo l'avvio

ANY.RUN segnala il comportamento **“Drops the executable file immediately after the start”**. Il file associato all'evento è `C:\Users\admin\AppData\Local\Temp\delays.tmp`. La creazione di un file nella cartella temporanea, presa isolatamente, non sarebbe necessariamente malevola; in questo caso diventa però significativa perché avviene all'interno di una catena già classificata come malevola e insieme ad altre evidenze indipendenti.

Lo screenshot riporta anche gli hash del file, utili come indicatori di compromissione (IOC):

MD5: 4358f43fd60efd8274a7dc9f7848b860

SHA1: 0474c2f110966870c732774b8bace297162cfe6

SHA256: 629758e18092451ceb917986ad6ed0251f984e8527e2a49a843977b91813b195

+ null	Drops the executable file immediately after the start	Hide
Filename:	C:\Users\admin\AppData\Local\Temp\delays.tmp	
Md5:	4358f43fd60efd8274a7dc9f7848b860	
Sha1:	0474c2f110966870c732774b8bace297162cfe6	
Sha256:	629758e18092451ceb917986ad6ed0251f984e8527e2a49a843977b91813b195	
+ null	Drops the executable file immediately after the start	Hide
Filename:	C:\Users\admin\AppData\Local\Temp\delays.tmp	
Md5:	4358f43fd60efd8274a7dc9f7848b860	
Sha1:	0474c2f110966870c732774b8bace297162cfe6	
Sha256:	629758e18092451ceb917986ad6ed0251f984e8527e2a49a843977b91813b195	
+ null	Drops the executable file immediately after the start	Hide
Filename:	C:\Users\admin\AppData\Local\Temp\delays.tmp	
Md5:	4358f43fd60efd8274a7dc9f7848b860	
Sha1:	0474c2f110966870c732774b8bace297162cfe6	
Sha256:	629758e18092451ceb917986ad6ed0251f984e8527e2a49a843977b91813b195	
+ null	Drops the executable file immediately after the start	Hide
Filename:	C:\Users\admin\AppData\Local\Temp\delays.tmp	
Md5:	4358f43fd60efd8274a7dc9f7848b860	
Sha1:	0474c2f110966870c732774b8bace297162cfe6	
Sha256:	629758e18092451ceb917986ad6ed0251f984e8527e2a49a843977b91813b195	
+ null	Drops the executable file immediately after the start	Hide
Filename:	C:\Users\admin\AppData\Local\Temp\delays.tmp	
Md5:	4358f43fd60efd8274a7dc9f7848b860	
Sha1:	0474c2f110966870c732774b8bace297162cfe6	
Sha256:	629758e18092451ceb917986ad6ed0251f984e8527e2a49a843977b91813b195	

Figura 4 – Dettaglio dell'evento relativo al file `delays.tmp` e ai relativi hash.

5. Altri comportamenti osservati

5.1 Attività di discovery

Nella timeline del processo sono presenti anche due tecniche di discovery mappate da ANY.RUN: **T1012 – Query Registry** e **T1082 – System Information Discovery**. In particolare, la piattaforma indica controlli relativi alle lingue supportate. Queste attività non sono, da sole, una prova di malware, ma sono compatibili con una fase di raccolta di informazioni sull'ambiente prima o durante l'esecuzione.

5.2 Attività di rete e download di eseguibili

La panoramica generale mostra richieste HTTP provenienti da un processo RegAsm.exe verso l'host **174.5.44.104**, con risposta HTTP 200 e download di contenuti identificati come **executable**, inclusi file con nomi del tipo `..._lawng.exe` e `..._xerek.exe`. Questo è un elemento particolarmente rilevante perché collega la catena di esecuzione al recupero di ulteriori eseguibili da rete.

Nella stessa panoramica compaiono inoltre più segnalazioni di rete, tra cui *Potentially Bad Traffic*, *Potential Corporate Privacy Violation* e **“A Network Trojan was detected”**, con messaggio relativo a **STEALER[ANY.RUN] Lumma Stealer TLS Connection**. Alcune etichette di rete sono euristiche o di policy e, considerate singolarmente, non dimostrano necessariamente una compromissione; nel contesto complessivo, però, rafforzano ulteriormente la valutazione di vero positivo.

La vista dei file mostra inoltre la presenza di più artefatti ed eseguibili/DLL in directory come `C:\ProgramData\...` e nella cache Internet. Non attribuisco automaticamente ogni singolo file al payload principale, ma il numero di artefatti generati e la presenza di ulteriori eseguibili sono coerenti con una catena di download/esecuzione.

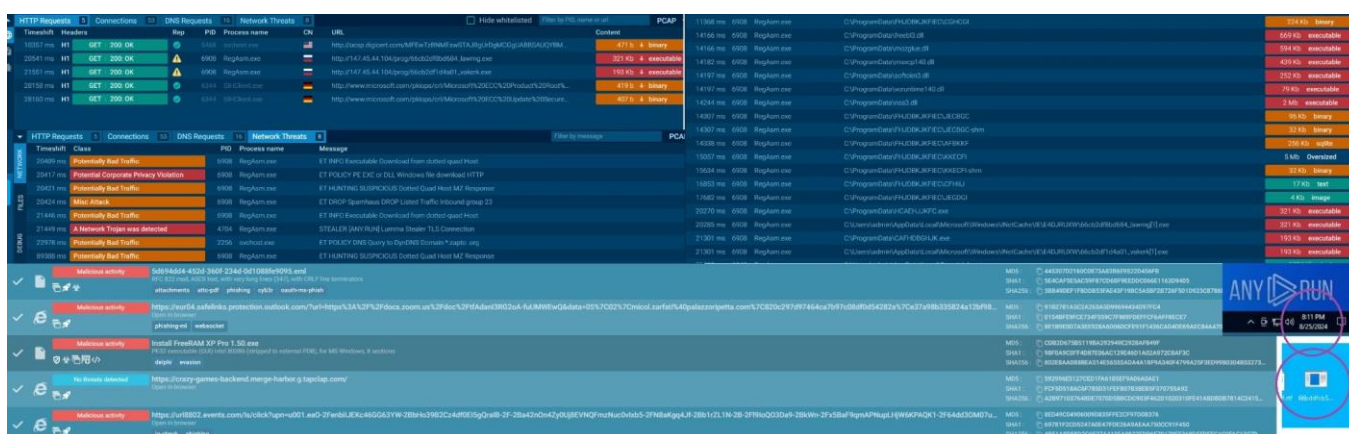


Figura 5 – Panoramica degli indicatori di rete, dei file osservati e delle segnalazioni di attività malevola.

6. Valutazione e decisioni di risposta

Sulla base delle evidenze raccolte, classificherei il caso come **vero positivo**. Il motivo non è il solo punteggio di ANY.RUN, ma la convergenza di più elementi: verdetto 100/100, rilevazione YARA di VIDAR, comportamento di drop di un file subito dopo l'avvio, attività di discovery, download HTTP di ulteriori eseguibili e segnalazioni di rete riconducibili a un trojan/stealer.

Azioni che adotterei:

1	Isolare il sistema dalla rete	Se il comportamento fosse osservato su una macchina reale, l'isolamento immediato ridurrebbe il rischio di ulteriori download, comunicazioni o furto di dati.
2	Mettere in quarantena il campione e gli artefatti associati	Prima della cancellazione conserverei copie e log necessari all'analisi. Successivamente procederei alla rimozione controllata.
3	Non bloccare globalmente RegAsm.exe	È una utility Microsoft legittima. Bloccarla indiscriminatamente potrebbe causare problemi al sistema o alle applicazioni .NET. È preferibile rilevare l'abuso tramite contesto, catena di processi e IOC.
4	Bloccare temporaneamente gli indicatori di rete osservati	In particolare l'host da cui vengono scaricati eseguibili sospetti. Il blocco dovrebbe essere validato dall'infrastruttura di sicurezza prima di diventare permanente.
5	Cercare gli IOC sugli altri endpoint	Ricerca di hash, nomi file, percorsi e indicatori di rete per verificare se la stessa minaccia abbia raggiunto altri sistemi.
6	Gestire il rischio credenziali	Poiché gli indicatori richiamano malware stealer, considererei potenzialmente esposte credenziali, cookie e sessioni: reset delle password, revoca delle sessioni e controllo MFA.
7	Verificare persistenza e processi correlati	Controllo di attività residue, process tree, file in ProgramData/Temp/cache e meccanismi di avvio automatico.

7. Conclusione

In conclusione, il primo link ANY.RUN non presenta un semplice comportamento sospetto isolato, ma una serie coerente di evidenze di compromissione. La detection YARA di VIDAR, il punteggio 100/100, la creazione di artefatti temporanei, la presenza di una catena che utilizza RegAsm.exe e processi di supporto, i download di ulteriori eseguibili e le segnalazioni di rete verso comportamenti da stealer/trojan portano a classificare il campione come **malware reale e non come falso positivo**.

La scelta operativa più corretta sarebbe quindi **isolamento, quarantena, raccolta delle evidenze, ricerca degli IOC e successiva bonifica**. Non bloccherei invece indiscriminatamente RegAsm.exe, perché il binario è legittimo: ciò che risulta malevolo è il suo utilizzo all'interno della specifica catena osservata.